

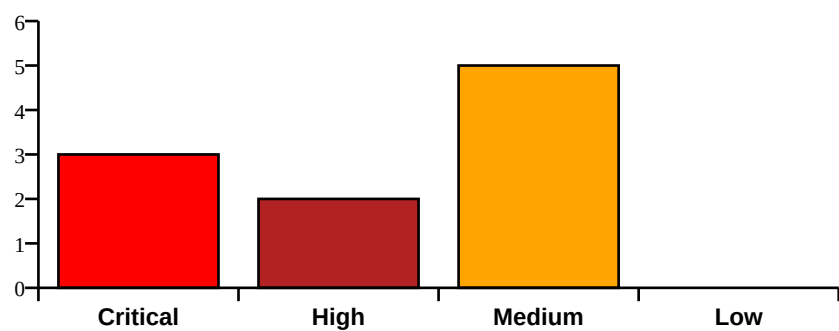
Vulnerability Scan Report

Target URL: http://localhost:3000
Generated (UTC): 2026-04-25 09:01:32Z

Summary

Metric	Count
Total Vulnerabilities	10
Critical Severity	3
High Severity	2
Medium Severity	5
Low Severity	0

Severity Distribution



Detailed Findings

1. Identification & Authentication Failures (Medium)

Location: http://localhost:3000

Payload: continueCode → Secure=False

Evidence:

Cookie transmitted without Secure flag.

2. Identification & Authentication Failures (Medium)

Location: http://localhost:3000

Payload: continueCode → HttpOnly=False

Evidence:

Cookie accessible via JavaScript (XSS risk).

3. Identification & Authentication Failures (Medium)

Location: http://localhost:3000

Payload: token → Secure=False

Evidence:

Cookie transmitted without Secure flag.

4. Identification & Authentication Failures (Medium)

Location: http://localhost:3000

Payload: token → HttpOnly=False

Evidence:

Cookie accessible via JavaScript (XSS risk).

5. Identification & Authentication Failures (High)

Location: http://localhost:3000

Payload: exp field missing

Evidence:

JWT does not expire – can be reused indefinitely.

6. Identification & Authentication Failures (Critical)

Location: http://localhost:3000

Payload: data.password = 0192023a7bbd73250516f069df18b500

Evidence:

Sensitive data exposed inside JWT payload.

7. Identification & Authentication Failures (Critical)

Location: http://localhost:3000

Payload: data.deluxeToken =

Evidence:

Sensitive data exposed inside JWT payload.

8. Identification & Authentication Failures (Critical)

Location: http://localhost:3000

Payload: data.totpSecret =

Evidence:

Sensitive data exposed inside JWT payload.

9. Identification & Authentication Failures (Medium)

Location: http://localhost:3000

Payload: role = admin

Evidence:

User role exposed in JWT.

10. Identification & Authentication Failures (High)

Location: http://localhost:3000

Payload: Token stored in browser localStorage

Evidence:

Token accessible via JavaScript (XSS risk).

Activity Log

```
[09:01:19]
=====
[09:01:19] Starting Vulnerability Scan for http://localhost:3000
[09:01:19]
=====
[09:01:19] [*] Starting dynamic crawl (Async Playwright)...
[09:01:20] [*] Attempting automatic login...
[09:01:21] [!] Dynamic crawl failed: You cannot call this from an async context - use a thread or
sync_to_async.
[09:01:21] [*] Falling back to static crawl.
[09:01:25] [+] Looking for login form...
[09:01:28] [+] Found login form at http://localhost:3000/#/login
[09:01:28] [+] Login form detected dynamically.
[09:01:28] [+] Logging in with provided credentials...
[09:01:30] [+] Analyzing cookies...
[09:01:30] [!] Missing Secure flag on continueCode
[09:01:30] [!] Missing HttpOnly flag on continueCode
[09:01:30] [!] Missing Secure flag on token
[09:01:30] [!] Missing HttpOnly flag on token
[09:01:30] [+] Analyzing JWT token...
[09:01:30] [+] JWT token found.
[09:01:30] [JWT HEADER] {
  "typ";: "JWT";,
  "alg";: "RS256";
}
[09:01:30] [JWT PAYLOAD] {
  "status";: "success";,
  "data";: {
    "id";: 1,
    "username";: "";,
    "email";: "admin@juice-sh.op";,
    "password";: "0192023a7bbd73250516f069df18b500";,
    "role";: "admin";,
    "deluxeToken";: "";,
    "lastLoginIp";: "";,
    "profileImage";: "assets/public/images/uploads/defaultAdmin.png";,
    "totpSecret";: "";,
    "isActive";: true,
    "createdAt";: "2026-04-25 05:56:43.670 +00:00";,
    "updatedAt";: "2026-04-25 05:56:43.670 +00:00";,
    "deletedAt";: null
  },
  "iat";: 1777107688
}
[09:01:32]
[*] Generating PDF report...
```